

1. Federacja tożsamości

1.1 Czym jest i jakie ma zastosowania?

Federacja tożsamości to mechanizm, który pozwala używać jednej tożsamości (jednego konta) do logowania się w wielu różnych, niezależnych systemach i usługach. Zamiast tworzyć osobne konto w każdym serwisie, logujesz się przez jednego zaufanego dostawcę tożsamości (Identity Provider).

Zastosowania: logowanie do aplikacji firmowych jednym kontem (np. przez Azure AD), dostęp do usług chmurowych, współpraca między organizacjami (np. pracownik firmy A loguje się do systemu firmy B swoim firmowym kontem), e-administracja (profil zaufany).

1.2 Przykład z codziennego życia:

Przycisk "Zaloguj się przez Google" lub "Zaloguj się przez Facebook" na stronach takich jak Spotify, Canva czy Allegro. Masz jedno konto Google i używasz go do logowania w dziesiątkach różnych serwisów bez tworzenia nowych haseł.

2. SSO przez Google

2.1 Jak działa "Sign in with Google"?

Klikasz "Sign in with Google" na stronie trzeciej. Strona przekierowuje cię na serwer Google. Logujesz się na swoje konto Google (lub jesteś już zalogowany). Google pyta czy zgadzasz się udostępnić dane tej aplikacji. Po wyrażeniu zgody Google generuje token i przekazuje go z powrotem do aplikacji. Aplikacja weryfikuje token i tworzy twoją sesję. W żadnym momencie aplikacja nie widzi twojego hasła do Google — dostaje tylko token potwierdzający twoją tożsamość. Cały proces opiera się na protokole OAuth 2.0 i OpenID Connect.

2.2 Jakie informacje Google przekazuje?

Podstawowe: adres e-mail, imię i nazwisko, zdjęcie profilowe, unikalny identyfikator konta Google. W zależności od uprawnień o jakie prosi aplikacja, może to być też dostęp do kalendarza, kontaktów, plików na Dysku Google itp. Zawsze widzisz listę uprawnień przed wyrażeniem zgody.

3. Authentication vs Authorization

3.1 Różnica:

Authentication (uwierzytelnianie) to potwierdzenie KIM jesteś — udowadniasz swoją tożsamość, np. podając login i hasło, skan odcisku palca, kartę dostępu.

Authorization (autoryzacja) to sprawdzenie DO CZEGO masz prawo — system decyduje jakie zasoby i akcje są dla ciebie dostępne na podstawie twoich uprawnień.

Najpierw zawsze zachodzi authentication, potem authorization. Najpierw system sprawdza kim jesteś, a dopiero potem co ci wolno.

3.2 Przykład gdzie authentication się udaje, ale authorization nie:

Logujesz się do firmowego systemu swoim kontem (authentication OK — system wie że to ty). Próbujesz wejść do folderu z dokumentami zarządu, ale dostajesz komunikat "Brak dostępu" — bo twoje konto ma uprawnienia zwykłego pracownika, nie dyrektora (authorization odmówiona). Tożsamość potwierdzona, ale brak uprawnień do zasobu.

4. MFA w praktyce

4.1 Dlaczego Google Authenticator jest bezpieczniejszy niż SMS?

SMS można przechwycić przez atak SIM swap (oszust przenosi twój numer na swoją kartę SIM dzwoniąc do operatora). SMS przechodzi przez sieć komórkową, którą można podsłuchiwać. SMS-y mogą być przekierowane przez złośliwe oprogramowanie na telefonie.

Google Authenticator generuje kody offline, lokalnie na urządzeniu. Kody nie są nigdzie przesyłane przez sieć, więc nie można ich przechwycić w transmisji. Kody zmieniają się co 30 sekund i są oparte na algorytmie TOTP (Time-based One-Time Password).

4.2 Backup codes:

Backup codes (kody zapasowe) to jednorazowe kody awaryjne, które generujesz z wyprzedzeniem i zapisujesz w bezpiecznym miejscu (np. drukujesz na kartce, zapisujesz w menedżerze haseł).

Używasz ich gdy stracisz dostęp do telefonu (zgubienie, kradzież, awaria), nie możesz uruchomić aplikacji authenticator, lub nie masz dostępu do żadnej innej metody MFA. Każdy kod działa tylko raz. Bez nich utrata telefonu może oznaczać trwałą utratę dostępu do konta.